

Banking Shield

Mohammad Raouf Abedini

Banking Shield: Machine-Checked Absence Claims for Privacy-Sensitive AI Explanations

Version 1.2, preprint candidate, 2026-06-13. This version incorporates the Stage B5-D full-paper draft, citation verification, final paper-readiness audit, Stage B5-R model-assisted hostile review, and a post-review writing revision. Academic citations carry DOIs; standards and industry scheme citations use stable institutional URLs. All empirical facts trace to the Stage B5 evidence pack (repo `main @ 92dabb4`) and were re-audited against checkout `3dcf21b` on 2026-06-13 before paper-only edits. The manuscript makes no fraud-detection, scam-prevention, payment-safety, payee-verification, financial-advice, compliance, or production-readiness claims. Substantial LLM assistance was used in drafting and is disclosed in §11.

Preprint status. This manuscript is an author-prepared preprint supported by automated test, audit, claim-review, and model-assisted adversarial-review evidence. It has not yet undergone formal peer review, external banking review, or independent security validation.

Abstract

AI-style explanations are attractive in sensitive research prototypes because they can help participants understand what a system did. They are also the place where privacy and capability boundaries most often blur: an explanation layer may receive data the prototype should not hold, send that data to a provider, or describe capabilities the prototype does not have. Banking Shield tests a narrower design goal: can a prototype make useful explanation artifacts while producing machine-checkable evidence about what the explanation layer did not receive, did not transmit, and did not claim? We present a fictional, non-bank, research-only banking-adjacent prototype whose main artifact is bounded evidence of absence: gate-backed evidence that sensitive values were not recorded in the frozen evidence pack and did not enter the explanation payload. The system combines a fail-closed metadata firewall whose rejections become audit evidence, per-session tamper-evident HMAC audit chains with withdrawal se-

mantics, and a deterministic offline AI-style privacy firewall: allowlist input construction, a deterministic mock narrative provider, a negation-aware output claim firewall, per-response privacy receipts, and a static source gate over the four AI-firewall modules for network primitives. At the evidence freeze, all automated gates passed (417/417 unit tests; 43/43 end-to-end checks; 27/27 security checks; three privacy audits), and five trusted internal testers completed 30 formative sessions with zero sensitive values in the evidence and 5/5 checklist comprehension of the system’s non-claims. The prototype does not evaluate banking effectiveness or live LLM safety. Its contribution is a reproducible pattern for turning privacy and overclaim boundaries into testable system properties.

1 Introduction

Banking Shield is a fictional banking-adjacent research prototype. It has no connection to any bank, processes no real financial data, and makes no fraud-detection, scam-prevention, payment-safety, payee-verification, financial-advice, or compliance claims. That constraint is not a footnote; it is the object of study. The prototype asks how a system can help a participant inspect a sensitive workflow while proving, within a bounded artifact set, that it did not collect prohibited values or let its explanation layer exceed the system’s actual capability.

Sensitive-domain prototypes usually argue safety through policy language (“we do not collect X”) and argue explanation quality through behavioural language (“the model rarely says Y”). Those arguments leave three engineering gaps:

- **G1: Explanation layers leak by default.** An LLM-backed explanation feature typically receives the session record and emits free text; nothing structural prevents sensitive input or unbounded output.
- **G2: Overclaims are unpoliced.** Nothing stops an explanation layer from asserting capabilities (“fraud detected”) that the system does not have; in regulated-adjacent domains this is the costliest failure mode.
- **G3: Absence of data is rarely evidenced.** Systems log what they did, not what they refused; a participant cannot verify that nothing sensitive was recorded.

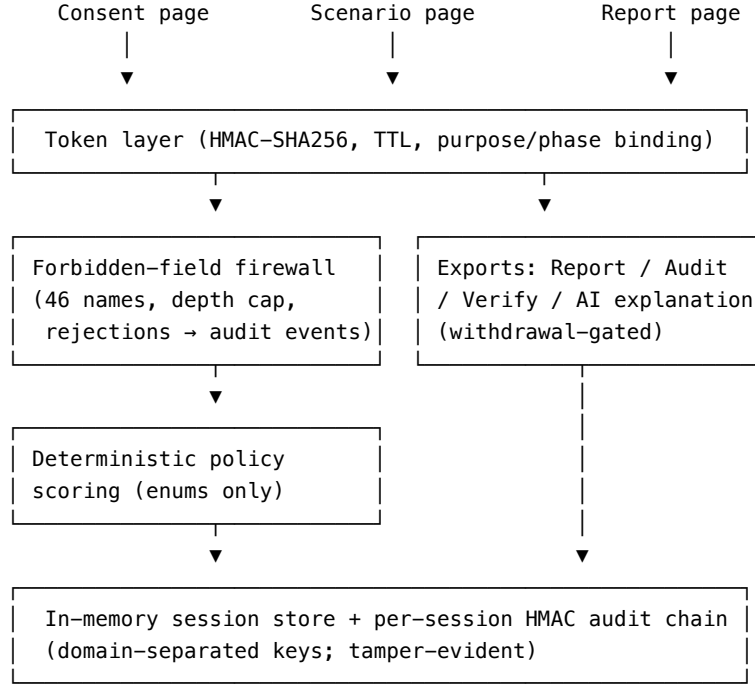
Our thesis: **privacy-sensitive explanation should start with structure, not moderation.** A prototype should construct the smallest possible explanation payload, fail closed before provider invocation, block unsupported claims after generation, and leave receipts that let a participant or reviewer inspect the boundary. Contributions:

- **C1** A metadata-only integrity-evidence architecture: a recursive forbidden-field firewall (46 key names, including prototype-pollution keys) whose rejections are audit events that escalate subsequent policy scoring; refusals become evidence (§4.1).
- **C2** A deterministic, offline AI privacy firewall: allowlist input contract, deterministic narrative provider, fail-closed output claim firewall, per-

response privacy receipt, and a static source no-egress check over the four AI-firewall modules with a negative self-test (§4.2, Figure 3).

- **C3** Claim discipline as a mechanism: a negation-aware scanner that blocks affirmative capability phrasing while passing required disclaimers, enforced at runtime and mirrored by repository CI (§4.3).
- **C4** A verifiable participation lifecycle: consent, withdrawal, HMAC audit chains, and aggregate-only human evidence, exercised in a formative internal dry run (§4.4, §6.2).

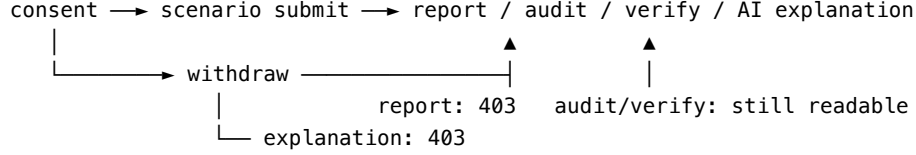
Figure 1: Banking Shield architecture. *Every write passes the forbidden-field firewall before validation; every export is token-bound and chained. The system is metadata-only by construction (C1).*



2 Background and Motivation

A Banking Shield session asks a participant to consent, complete one of five fictional scenarios, and inspect exports: a Report, an Audit listing, a Verify check, and, behind a default-off flag, an AI-style explanation (Figure 2). The scenarios resemble sensitive banking-adjacent moments: a mock data-sharing consent screen, a mock payee-name check, a remote-access caution, a payment-pause prompt, and an AI-agent finance approval. All scoring is a local deterministic function over enumerated metadata. The labels safe/warning/critical are fictional prototype outputs, not calibrated alerts.

Figure 2: Session lifecycle. *Withdrawal blocks report and explanation export (403) but preserves audit/verify reads for transparency (C4).*



Three observations from the project evidence shaped the design:

- **O1.** Every prohibited input class the project tested (46 field names: credentials, OTPs, account identifiers, amounts, payees, device telemetry, and structural pollution keys) appeared only in attack-style tests. Each was rejected and logged. Refusal-as-evidence is therefore mechanically achievable within this prototype.
- **O2.** In the formative dry run, all five testers understood the non-claims (5/5 on fictional-only, no-bank-connection, no-fraud-detection, no-financial-advice, withdrawal), but only one of five initially understood the Report/Audit/Verify exports. Interpretability, not privacy, was the weak point. That result motivated the explanation layer and matches the broader finding that warning comprehension depends strongly on text characteristics and terminology (Lindell & Perry 2011, doi:10.1111/j.1539-6924.2011.01647.x; Scherr et al. 2015, doi:10.1002/acp.3195).
- **O3.** The explanation layer is the riskiest place to improve interpretability because it sits at the boundary between internal evidence and reader-facing language. The design therefore treats the explanation layer as an adversarial surface, not a cosmetic feature.

Table 1: Allowed vs forbidden data (T1).

Allowed into the narrative payload (allowlist)	Forbidden everywhere (46-name denylist, classes)
Hashed session id	Credentials and one-time codes
Scenario type (enum)	Account/card/payment identifiers
User action/decision category (enum)	Amounts, balances, payees, references
Policy outcome + score (deterministic)	Transaction/statement content
Manual-review flag (boolean)	Screens, recordings, keystrokes, clipboard
Privacy-assertion booleans	Window titles, process/app names, device ids
No free-text payload	<code>__proto__</code> , <code>prototype</code> , <code>constructor</code>

3 Threat Model

Assets. A1 sensitive banking payloads (must never enter); A2 audit-chain integrity; A3 the claim boundary; A4 participant anonymity; A5 official policy-result integrity.

Table 2: Threats and controls (T5).

Threat	Controls	Asset
T1 Sensitive/polluted submission	Recursive denylist firewall, depth cap, body cap, rejection audit events, score escalation	A1
T2 Provider exfiltration (future live LLM)	Allowlist input (hashed id, enums), 4 KB cap, static no-egress gate, deterministic mock provider	A1
T3 Capability overclaim in narrative	Output schema allowlist, length caps, negation-aware claim scan, fail-closed rejection	A3
T4 Narrative drifts official result	Equality check against the authoritative record	A5
T5 Audit-log tampering	Per-session HMAC chains, domain-separated keys; tampered fixtures fail verification	A2
T6 Token theft/replay	HMAC tokens, constant-time compare, TTL, purpose/phase binding, path/token match	A1,A4
T7 Withdrawal bypass	Withdrawn $\rightarrow$ 403 on report/explanation; audit/verify intentionally readable	A4

Trust assumptions and residual risks. The server, its secrets, and transport security are trusted; Phase B testers are trusted insiders. The audit chain is tamper-evident, not tamper-proof: the server holds the keys, a limitation shared by server-side secure-logging schemes generally, which motivates third-party or distributed verification in that literature (Sree & Bhanu 2019, doi:10.1002/cpe.5143; Ali et al. 2021, doi:10.1002/ett.4272). Denylist scanning is incomplete by construction. Receipts attest process, not ground truth. Withdrawal does not erase the metadata-only audit chain; the prototype discloses that choice. The evaluation does not cover DoS beyond rate limiting, side channels, browser compromise, or a malicious operator.

4 Design

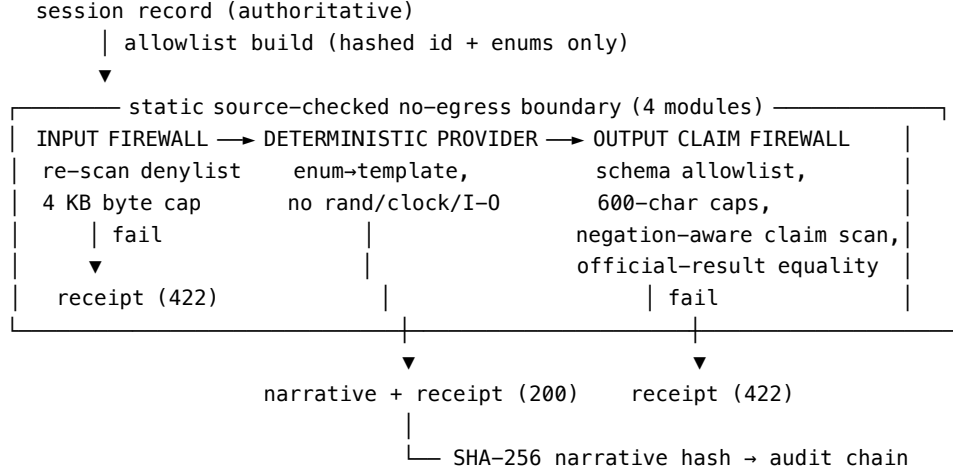
Banking Shield uses the same rule at every boundary: construct what is allowed, reject what is not, and record the rejection without recording the prohibited value. The architecture applies that rule to submitted metadata, exports, explanation inputs, explanation outputs, and participant withdrawal.

4.1 Metadata-only integrity evidence (C1)

Every write passes through a recursive forbidden-field firewall before schema validation. The firewall blocks 46 key names spanning credentials, financial identifiers, content fields, device telemetry, and the structural pollution keys `__proto__/prototype/constructor`; it also enforces a recursion-depth cap and a 16 KB body limit. A rejection appends an audit event containing the route, reason, and field name, never the value. The session’s later policy score escalates after a rejection, so an attack attempt becomes part of the integrity record rather than a discarded exception. This operationalises the data-minimisation principle, collect only what the stated purpose requires (Klein et al. 2021, doi:10.1111/1911-3846.12735; Yeung & Bygrave 2021, doi:10.1111/rego.12401) as an enforced, evidence-producing mechanism rather than a policy statement; no compliance property is claimed or implied. *Alternative considered:* schema-level allowlisting alone. The project rejected that as insufficient: an allowlist validates shape, but it does not produce evidence of hostile attempts. Banking Shield therefore uses both controls. The allowlist defines the valid shape; the denylist converts prohibited attempts into auditable signal.

4.2 The deterministic AI privacy firewall (C2)

Figure 3: The AI privacy firewall (page-one figure candidate). *The no-egress boundary is source-checked over the four AI-firewall modules; every stage fails closed to a receipt, never to a narrative (C2).*



The explanation endpoint exists to make the report understandable without turning the explanation layer into a privacy sink. It therefore has four fail-closed stages:

1. **Input firewall.** The narrative payload is *constructed*, not passed through: a hashed session id, scenario/action enums, the policy outcome, and the privacy-assertion booleans. The assembled payload is re-scanned against

the forbidden-field denylist (defence in depth) and capped at 4 KB. Failure returns a receipt, never a narrative.

2. **Deterministic provider.** Narrative text is an enum-to-template pure function: no randomness, no clock, no I/O. A static source gate checks that the four AI-firewall modules import no network primitive, and a negative self-test confirms the gate fails when a network primitive is injected. This is not a host-level egress-control claim.
3. **Output claim firewall.** The narrative must match an exact top-level schema (field allowlist), respect 600-character caps per field, contain a non-empty non-claims list, and pass a negation-aware scan over 28 affirmative-capability phrasings; an equality check proves the narrative did not drift the official result.
4. **Privacy receipt.** Every response, whether successful, blocked, or disabled, carries a receipt: provider identity (`deterministic_mock`), `sensitive_payload_sent_to_ai:false`, `network_egress_used:false`, official-result and claim-guard flags, and a success-only SHA-256 narrative hash that is also written into the session’s audit chain.

Alternative considered: a live LLM behind the same firewall. The project rejected it for this paper because it would convert the no-egress property from static source evidence into an operational assertion. The input allowlist, byte cap, output schema, claim scan, and receipt mechanism would survive a future live provider. Determinism and reproducible narrative hashing would not; a live provider would require replay logging and separate provider-risk evaluation. The mock therefore establishes the contract and enforcement points, not live-model safety.

4.3 Claim discipline as a mechanism (C3)

The output firewall’s scanner is negation-aware. Required disclaimers such as “not fraud detection” and “not a fraud detection tool” pass; affirmative phrasing and weakened negation such as “not really a ...” are blocked. The scanner is intentionally conservative: a false positive blocks a narrative, and the paper claims no complete false-negative class. Repository CI enforces the same boundary with an overclaim-wording scanner. During integration, that scanner flagged the firewall’s own denylist because the denylist contains the phrases it blocks. The project resolved the conflict with an explicit scanner exclusion rather than string obfuscation. Claim discipline is therefore checked at runtime and again at repository level.

4.4 Verifiable participation lifecycle (C4)

Each session carries an HMAC-SHA256 audit chain with domain-separated keys: participant-code hashing and chain signing cannot be cross-validated. Participants can export a Report, an Audit listing, and a Verify check of chain consistency. The Report contains explicit privacy assertions; the sensitive-data assertions remain `false` when the firewall has blocked prohibited input. Withdrawal

blocks Report and explanation export, but keeps Audit and Verify readable so a participant can still inspect the chain. The human-evidence pipeline stores only aggregate counts.

Table 3: Claims vs non-claims (T4).

The paper claims	The paper does NOT claim
Metadata-only integrity evidence (about the process)	Fraud detection or scam prevention
A fictional banking-adjacent prototype	Real banking protection or payment safety
A trusted internal dry run (formative)	Real payee verification or financial advice
A deterministic AI privacy firewall (contract + gates)	CDR/APRA/AML/CTF compliance
AI-style explanation without sensitive payloads	Production readiness or bank-grade security

5 Implementation

The implementation uses Node.js/Express, static HTML/CSS/JS tester pages, an in-memory session store, and shell/Node CI gates. The explanation panel writes through `textContent` only. The explanation endpoint sits behind a default-off flag requiring the exact string `"true"`; requests must be token-bound, path-matched, and within the read-rate limit. The prototype is single-node and research-only.

6 Evaluation

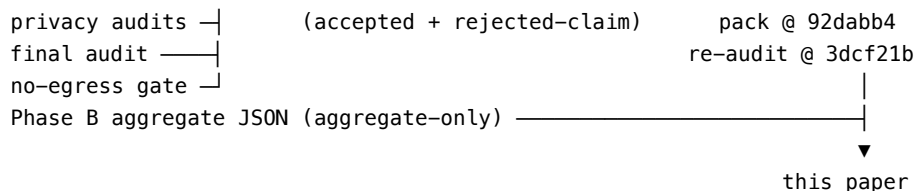
The evaluation is bounded by the prototype’s research-only scope. It asks three questions:

- **E1.** Do the structural controls pass their automated gates?
- **E2.** Can trusted insiders complete the lifecycle and understand the prototype’s non-claims?
- **E3.** Does the explanation firewall pass a clean narrative and block a poisoned one?

Figure 4 shows how evidence flows from gates, fixtures, and aggregate dry-run records into the paper.

Figure 4: Evidence pipeline. *Every claim in this paper traces to a gate, fixture, or frozen aggregate (E1–E3).*

unit tests $\neg$
smoke gates $\neg$
security audit $\dashv \rightarrow$ generated, attack-scanned fixtures $\rightarrow$ frozen evidence



6.1 Gate results (E1)

Hypothesis: the prototype’s claimed structural properties can be checked mechanically. *Result:* at the evidence freeze, every automated gate passed (Table 4). The claim is deliberately narrow: the gates passed for the frozen prototype and evidence pack. The result does not establish production security or regulatory compliance.

Table 4: Gate results at evidence freeze (T3).

Gate	Result
Unit tests	417/417 pass
Banking smoke	14/14 pass
AI firewall smoke	5/5 pass
Full banking E2E smoke	43/43 pass (incl. tamper-evidence check)
Banking security audit	27/27 pass
Banking privacy audits	all 3 PASS
No-egress static gate	PASS (with negative self-test)
Dependency audit	0 vulnerabilities
Repository CI quality gate	green

6.2 Formative internal dry run (E2, exploratory)

Hypothesis: trusted insiders can complete the lifecycle and understand the non-claim checklist. *Result:* five trusted internal testers completed 30 sessions (Table 5). No tester entered real banking values; the evidence pack contained zero sensitive values; the deterministic policy pattern reproduced identically across testers (safe/warning/warning/warning/safe across the five scenario types); all five withdrawals blocked later report export; and all five testers passed the five-item non-claim checklist. The weak point was export interpretability: only 1/5 initially understood the Report/Audit/Verify exports. A focused 3-session rerun confirmed revised copy, but it cannot establish improvement; we report it only as a design iteration. This is a formative dry run with n=5 trusted insiders, not a user study and not a representative banking-customer sample.

Table 5: Phase B aggregates (T2, exploratory).

Measure	Value
Trusted internal testers	5
Total sessions	30
Submitted scenario sessions	25 (5 per scenario)
Withdrawal sessions	5
Withdrawals blocking later report export	5/5
Real banking values entered	0
Sensitive values found in evidence	0
Forbidden payload structures in evidence	0
Comprehension: fictional-only	5/5
Comprehension: no bank connection	5/5
Comprehension: no fraud detection	5/5
Comprehension: no financial advice	5/5
Comprehension: withdrawal	5/5
Export interpretability (pre copy-patch)	1/5 (design iteration followed)

6.3 Fixture studies (E3)

Hypothesis: the output firewall passes a clean narrative and blocks a poisoned one. *Result:* the accepted-explanation fixture, a clean generated narrative with receipt, passes all gates and contains no attack values. The rejected-claim fixture, a deliberately poisoned narrative asserting a detection capability, is blocked by the claim guard with the failed gate recorded in its receipt. The fixture pair demonstrates the firewall’s two required behaviours under controlled conditions.

7 Limitations

The strongest limitation is also the point of the paper: the provider is a deterministic mock. No live LLM has been filtered, evaluated, or validated. The mock lets the paper isolate the contract around an explanation provider, but it does not measure real model behaviour.

The human evidence is formative. Five trusted insiders completed the dry run; the paper makes no statistical claim, no representative-user claim, and no banking-customer comprehension claim. The result supports lifecycle feasibility and checklist comprehension within a trusted internal setting.

The security evidence is bounded. Denylist scanning is incomplete by construction, and adversarial phrasing can evade a phrase scanner. The allowlist construction is the stronger control. The gates are written by the project they validate; negative self-tests and public reproducibility reduce that risk but do not remove it. The prototype is single-node and in-memory. The audit chain is server-keyed, tamper-evident to participants, not tamper-proof against the operator. The no-egress claim is a static source check over the four AI-firewall modules, not a network sandbox or host-level egress-control guarantee.

8 Reproducibility and Review-Substitute Pack

The artifact includes the paper, evidence pack, final audit, claim audit, and Stage B5-R review-substitute pack under `docs/research/banking-pilot/paper/`. The Stage B5-R pack simulates five external-style hostile reviews (privacy/security, banking governance, HCI, AI safety, and reject-oriented reviewer #2 attack) and records author responses before preprint submission. This is not a replacement for formal peer review; it is a structured preprint-risk-reduction step.

The core reproduction gates are:

```
npm test
bash scripts/smoke-banking-pilot.sh
SIMURGH_BANKING_PILOT_AI_EXPLAIN=true bash scripts/smoke-banking-pilot-ai-firewall.sh
bash scripts/smoke-banking-pilot-full-e2e.sh
bash scripts/security-audit-banking-pilot.sh
node scripts/privacy-audit-banking-pilot.mjs
node scripts/privacy-audit-banking-pilot-phase-b.mjs
node scripts/privacy-audit-banking-pilot-ai-firewall.mjs
npm audit --audit-level=moderate
```

These gates support the paper’s mechanism and evidence-pack claims. They do not establish production security, regulatory compliance, live-LLM safety, or real-world banking effectiveness.

9 Related Work

Grouped by approach. Academic citations below were verified and carry DOIs; open-banking and payment-scheme citations use stable institutional sources.

Tamper-evident logging. Secure-logging schemes protect log integrity and authenticity with hash chains, MACs, and related structures, and survey the limits of server-trusted designs (Sree & Bhanu 2019, doi:10.1002/cpe.5143; Ali et al. 2021, doi:10.1002/ett.4272). We apply standard HMAC-chain machinery per-session, with participant-facing verify exports and withdrawal semantics; our chain is deliberately scoped as tamper-evident, not tamper-proof.

Warning and rights comprehension. Warning research shows comprehension hinges on reception, attention, and terminology (Lindell & Perry 2011, doi:10.1111/j.1539-6924.2011.01647.x), that recipients frequently take no action on textual alerts (Kim et al. 2019, doi:10.1111/1468-5973.12278), and that text characteristics measurably drive comprehension of rights-style warnings (Scherr et al. 2015, doi:10.1002/acp.3195). Banking Shield measures comprehension of *non-claims*, what the system does NOT do, as an inverted warning problem, in a formative setting only.

Data minimisation and design-based regulation. The GDPR’s data-minimisation and data-protection-by-design principles require systems to hold

only what their purpose strictly needs and to hard-wire protection into architecture (Klein et al. 2021, doi:10.1111/1911-3846.12735; Yeung & Bygrave 2021, doi:10.1111/rego.12401; Bradshaw & DeNardis 2019, doi:10.1002/poi3.195). Our firewall is one concrete design-based mechanism, with the additional property that refusals produce evidence; we claim no compliance status under any regulation.

LLM guardrails and AI risk frameworks. Guardrail practice moderates live model output with content filters, usage monitoring, and evaluation frameworks (Lee et al. 2024, doi:10.1111/bjet.13505), and AI trust/risk/security frameworks catalogue runtime enforcement and output filtering controls (Ray 2026, doi:10.1111/exsy.70213). These filter content from a live model; Banking Shield instead makes the provider structurally unable to receive sensitive input, statically unable to egress, and schema-bound on output, with content scanning only as the final layer.

Open-banking consent UX. Open-banking customer-experience guidance treats consent and access dashboards as critical user-control surfaces (Open Banking Implementation Entity n.d.; World Bank n.d.). Banking Shield does not evaluate real open-banking consent efficacy; it evidences the integrity of a fictional consent-style flow.

Payee-confirmation services. Confirmation-of-payee and verification-of-payee schemes perform account-name matching before payment initiation (Pay.UK n.d.; European Payments Council n.d.). Banking Shield’s payee scenario is fictional: the contribution is the metadata boundary, not name matching.

Per-response AI transparency artifacts. Model cards and datasheets document models or datasets as release-time artifacts (Mitchell et al. 2019, doi:10.1145/3287560.3287596; Gebru et al. 2021, doi:10.1145/3458723). Banking Shield’s receipts are narrower: per-response, machine-checked records of what the explanation pipeline did and did not receive.

10 Conclusion

Banking Shield asks a narrow systems question with practical consequences: can a sensitive research prototype add an explanation layer while preserving machine-checkable boundaries around data collection, provider input, network egress, and reader-facing capability claims? The prototype’s answer is a structural pattern: fail-closed metadata firewalls, a deterministic offline provider behind provider-independent enforcement points, machine-checked claim discipline, and per-response receipts anchored in tamper-evident audit chains. At the evidence freeze, every automated gate passed. In a formative five-tester dry run, participants completed the lifecycle, the evidence pack contained zero sensitive values, and all testers understood the non-claim checklist.

The contribution is not banking protection and not live-LLM validation. It is a

reproducible way to make absence claims inspectable: show what the system was allowed to construct, show what it rejected, show what the explanation provider received, and show what the output firewall would not let the system say. Future work should test the same contract with replay-logged live-provider integration, generated allowlist templates, externally countersigned receipts, independent security review, and a powered user study.

11 LLM-Assistance Disclosure

This paper was drafted with substantial assistance from a frontier language model operating under a logged, evidence-pack-constrained protocol (`docs/research/banking-pilot/stage-b5-model-paper/`): the model synthesised, critiqued, and drafted; it validated nothing. A second model-assisted independent-style review stage (`docs/research/banking-pilot/paper/review/`) simulated five hostile reviewer roles and produced an author response before this v1.1 preprint candidate. All factual statements trace to automated gate results, generated fixtures, frozen aggregate evidence, and explicit audit records. Citation candidates were verified before inclusion; unresolved placeholders are not retained in this version.

References

- Ali, A., Khan, A., Ahmed, M., & Jeon, G. (2021). BCALS: Blockchain-based secure log management system for cloud computing. *Transactions on Emerging Telecommunications Technologies*, 33(4). doi:10.1002/ett.4272
- Bradshaw, S., & DeNardis, L. (2019). Privacy by Infrastructure: The Unresolved Case of the Domain Name System. *Policy & Internet*, 11(1), 16–36. doi:10.1002/poi3.195
- European Payments Council. (n.d.). *Verification of Payee*. <https://www.europeanpaymentscouncil.eu/wlwe-do/other-schemes/verification-payee>
- Gebru, T., Morgenstern, J., Vecchione, B., Vaughan, J. W., Wallach, H., Daumé III, H., & Crawford, K. (2021). Datasheets for datasets. *Communications of the ACM*, 64(12), 86–92. doi:10.1145/3458723
- Kim, G., Martel, A., Eisenman, D., Prelip, M., Arevian, A., Johnson, K. L., & Glik, D. (2019). Wireless Emergency Alert messages: Influences on protective action behaviour. *Journal of Contingencies and Crisis Management*, 27(4), 374–386. doi:10.1111/1468-5973.12278
- Klein, A., Manini, R., & Shi, Y. (2021). Across the Pond: How US Firms’ Boards of Directors Adapted to the Passage of the General Data Protection Regulation. *Contemporary Accounting Research*, 39(1), 199–233. doi:10.1111/1911-3846.12735
- Lee, J., Hicke, Y., Yu, R., Brooks, C., & Kizilcec, R. F. (2024). The life cycle of large language models in education: A framework for understanding sources of bias. *British Journal of Educational Technology*, 55(5), 1982–2002. doi:10.1111/bjet.13505

- Lindell, M. K., & Perry, R. W. (2011). The Protective Action Decision Model: Theoretical Modifications and Additional Evidence. *Risk Analysis*, 32(4), 616–632. doi:10.1111/j.1539-6924.2011.01647.x
- Mitchell, M., Wu, S., Zaldivar, A., Barnes, P., Vasserman, L., Hutchinson, B., Spitzer, E., Raji, I. D., & Gebru, T. (2019). Model Cards for Model Reporting. *Proceedings of the Conference on Fairness, Accountability, and Transparency*, 220–229. doi:10.1145/3287560.3287596
- Open Banking Implementation Entity. (n.d.). *Consent & Data Sharing Management*. Open Banking Customer Experience Guidelines. <https://standards.openbanking.org.uk/customer-experience-guidelines/introduction/consent-mgmt/latest/>
- Pay.UK. (n.d.). *Confirmation of Payee*. <https://www.wearepay.uk/what-we-do/overlay-services/confirmation-of-payee/>
- Ray, P. P. (2026). A Review of TRiSM Frameworks in Artificial Intelligence Systems: Fundamentals, Taxonomy, Use Cases, Key Challenges and Future Directions. *Expert Systems*, 43(3). doi:10.1111/exsy.70213
- Scherr, K. C., Agauas, S. J., & Ashby, J. (2015). The Text Matters: Eye Movements Reflect the Cognitive Processing of Interrogation Rights. *Applied Cognitive Psychology*, 30(2), 234–241. doi:10.1002/acp.3195
- Sree, T. R., & Bhanu, S. M. (2019). Secure logging scheme for forensic analysis in cloud. *Concurrency and Computation: Practice and Experience*, 31(15). doi:10.1002/cpe.5143
- World Bank. (n.d.). *The Role of Consumer Consent in Open Banking*. <https://openknowledge.worldbank.org/entities/publication/5fa1c972-ea32-5504-a60f-42237b7385ac>
- Yeung, K., & Bygrave, L. A. (2021). Demystifying the modernized European data protection regime: Cross-disciplinary insights from legal and regulatory governance scholarship. *Regulation & Governance*, 16(1), 137–155. doi:10.1111/rego.12401